

INTERN DOCUMENT — niet publiceren. Bewaren zolang de verwerking plaatsvindt.

AVG art. 30 — intern document — 4 juli 2026

Verwerkingsverantwoordelijke: Dennis van Westbroek · KVK 74667653 · info@perfectsupplement.nl

Verwerkingsregister — PerfectSupplement.nl

Laatst bijgewerkt: 2026-07-16

Volgende geplande controle: 2026-08-01 (maandelijks)

Eigenaar: Dennis van Westbroek — verwerkingsverantwoordelijke

Archief verwerkersovereenkomsten: Documenten/documenten/perfectsupplement/privacy/

Verwerkingsverantwoordelijke

Veld	Waarde
Naam	Dennis van Westbroek
KvK	74667653
Contact	info@perfectsupplement.nl
Website	perfectsupplement.nl
FG aangesteld	Nee — niet verplicht bij huidige schaal en risicoprofiel

Verwerkingen

Onderstaande tabellen volgen het KVK-voorbeeld. Elke rij is een afzonderlijke verwerking.

1. Leefstijlcheck (intake)

Doel	Gepersonaliseerd leefstijl- en supplementadvies tonen op basis van antwoorden
Betrokkenen	Volwassen websitebezoekers (doelgroep mannen 40+); geen bewuste verwerking onder 16 jaar
Soort gegevens	Intake-antwoorden (answers, symptom_profile), afgeleide scores (domain_scores, urgency_level, profile_label), leeftijdscategorie (age_range), optioneel e-mailadres (marketing_email)
Bijzondere gegevens	Ja — gezondheidsgegevens (art. 9 AVG)
Ontvangers	Supabase (opslag, EU Frankfurt); Hetzner (applicatiehosting, EU Duitsland)
Grondslag	Art. 9 lid 2 sub a (expliciete toestemming) + art. 6 lid 1 sub a
Bewaartermijn	24 maanden (intake-retention.ts); bij intrekking anonimiseren/verwijderen

Beveiligingsmaatregelen	HTTPS/HSTS, RLS (anon key deny-all), server-side API-routes, HMAC-sessiecookie, input-allowlists, Turnstile + honeypot + rate limiting
Doorgifte buiten EU	Nee (data blijft in EU-verwerkers)

2. Account & dashboard

Doel	Passwordless account zodat gebruiker voortgang en trends over sessies heen kan zien
Betrokkenen	Gebruikers die vrijwillig inloggen
Soort gegevens	E-mailadres, account-id, login-tokens (gehasht), psf_account-cookie (HMAC), gekoppelde intake-sessies
Bijzondere gegevens	Ja — via gekoppelde intake (health data)
Ontvangers	Supabase; Resend (logincode-mail, VS — DPF)
Grondslag	Art. 9 lid 2 sub a (toestemming bij claim/koppeling) + art. 6 lid 1 sub a
Bewaartermijn	Account actief zolang cookie geldig (90 dagen) of tot verwijdering; login-tokens 15 min eenmalig
Beveiligingsmaatregelen	HMAC-cookie met issued-at/expiry, non-enumerating login-API, rate limit per IP en e-mail, OTP eenmalig
Doorgifte buiten EU	Ja — Resend (VS, EU-US Data Privacy Framework)

3. Nurture- en marketingmails

Doel	E-mailsequentie na intake (dag 0–30) met leefstijl-inhoud en herstelplan
Betrokkenen	Intake-gebruikers met marketingtoestemming
Soort gegevens	E-mailadres, voornaam (optioneel), profiel-snapshot (labels/scores), verzendstatus
Bijzondere gegevens	Ja — profiel-snapshot bevat afgeleide gezondheidsgegevens
Ontvangers	Resend (verzending)
Grondslag	Art. 9 lid 2 sub a + art. 6 lid 1 sub a (expliciete toestemming)
Bewaartermijn	12 maanden na verzending; recovery-links 72 uur eenmalig
Beveiligingsmaatregelen	Opt-in alleen na expliciete checkbox; unsubscribe in elke mail; pending mails geannuleerd bij intrekking
Doorgifte buiten EU	Ja — Resend (VS, DPF)

4. Herinnering herhaalmeting

Doel	E-mail na ~30 dagen om intake opnieuw in te vullen
-------------	--

Betrokkenen	Intake-gebruikers die reminder-opt-in gaven
Soort gegevens	E-mailadres, reminder-datum
Bijzondere gegevens	Nee (alleen contactgegevens; koppeling aan sessie via id)
Ontvangers	Resend; Supabase (intake_reminders)
Grondslag	Art. 6 lid 1 sub a (toestemming)
Bewaartermijn	Tot verzending + opruiming via retention-cron
Beveiligingsmaatregelen	Aparte toestemming; geannuleerd bij intrekking
Doorgifte buiten EU	Ja — Resend (VS, DPF)

5. Contactformulier

Doel	Beantwoorden van vragen en verzoeken van bezoekers
Betrokkenen	Websitebezoekers die contact opnemen
Soort gegevens	Naam, e-mailadres, bericht
Bijzondere gegevens	Nee (tenzij gebruiker zelf gezondheidsinfo in vrije tekst stuurt)
Ontvangers	Zoho CRM (EU)
Grondslag	Art. 6 lid 1 sub f (gerechtvaardigd belang — verwachte reactie)
Bewaartermijn	1 jaar
Beveiligingsmaatregelen	Turnstile op formulier; geen publicatie van berichten
Doorgifte buiten EU	Nee

6. Website-analytics (GA4 + Clarity)

Doel	Inzicht in gebruik van de website (funnels, paginaweergaven, heatmaps)
Betrokkenen	Alle websitebezoekers met cookietoestemming
Soort gegevens	Paginaweergaven, sessieduur, apparaattype, Clarity-sessieopnames (geen intake-data)
Bijzondere gegevens	Nee — intake-antwoorden worden niet naar analytics gestuurd
Ontvangers	Google Analytics (VS, DPF); Microsoft Clarity (VS, DPF/SCC)
Grondslag	Art. 6 lid 1 sub a (toestemming via cookiebanner)
Bewaartermijn	GA4: 14 maanden (GA4 property controleren); Clarity cookies: 1 dag–1 jaar

Beveiligingsmaatregelen	Consent-gate vóór laden scripts; Google Consent Mode v2 default-deny; modal cookiebanner met granulariteit (statistieken + marketing); affiliate-gate op partnerlinks; consent_records-audit bij banner-actie; Clarity uit op gezondheidsroutes; GA DPA geaccepteerd 23-11-2022; geen health data naar analytics
Doorgifte buiten EU	Ja — VS (DPF)

7. Interne product-events (domain_events)

Doel	Funnel-, retentie- en productverbeteringsanalyse (geanonimiseerde events)
Betrokkenen	Intake-gebruikers met anonymous_analytics-toestemming
Soort gegevens	Pseudoniem session_id, event-type, categorische payloads (domein, stap-id; geen vrije tekst)
Bijzondere gegevens	Nee in payloads — geen ruwe antwoorden of scores
Ontvangers	Supabase (domain_events, EU Frankfurt)
Grondslag	Art. 6 lid 1 sub a (toestemming anonymous_analytics)
Bewaartermijn	Volgt intake-retentie (24 maanden); anonimiseren bij consent-revoke
Beveiligingsmaatregelen	Client-allowlist op /api/intake/events; payload-minimalisatie (tracking-en-privacy.md)
Doorgifte buiten EU	Nee — events blijven in Supabase EU
Niet actief	Code bevat voorbereidingen voor externe analytics (PostHog) en automatisering (n8n), maar deze zijn niet geconfigureerd in productie (N8N_WEBHOOK_URL ontbreekt; geen PostHog-integratie). Bij activatie: register + privacyverklaring eerst bijwerken.

8. Affiliate-kliktracking

Doel	Metten welke affiliate-links worden geklikt (monetisatie)
Betrokkenen	Websitebezoekers die op affiliate-links klikken
Soort gegevens	Product-slug, timestamp, optioneel session_id, organization_id
Bijzondere gegevens	Nee
Ontvangers	Supabase (affiliate_clicks)
Grondslag	Art. 6 lid 1 sub f (gerechtvaardigd belang — commercieel inzicht)
Bewaartermijn	90 dagen
Beveiligingsmaatregelen	Geen PII in click-records; RLS
Doorgifte buiten EU	Nee

9. Beveiliging & fraudepreventie

Doel	Bescherming tegen spam, bots en misbruik
Betrokkenen	Alle websitebezoekers die formulieren/API's gebruiken
Soort gegevens	IP-adres (gehasht SHA-256), User-Agent (gehasht), Turnstile- en serverlogs
Bijzondere gegevens	Nee
Ontvangers	Cloudflare (Turnstile, CDN); Hetzner (serverlogs)
Grondslag	Art. 6 lid 1 sub f (gerechtvaardigd belang)
Bewaartermijn	Beveiligingslogs 90 dagen
Beveiligingsmaatregelen	Rate limiting, CSP, security headers, key-based SSH
Doorgifte buiten EU	Ja — Cloudflare wereldwijd (SCC's)

10. Toestemmingsregistratie (consent_records)

Doel	Bewijs van gegeven/introkken toestemming (compliance)
Betrokkenen	Intake-gebruikers
Soort gegevens	Exacte consent-tekst + versie, timestamp, ip_hash, ua_hash, scopes
Bijzondere gegevens	Ja — registreert toestemming voor art. 9-verwerking
Ontvangers	Supabase
Grondslag	Art. 6 lid 1 sub c (wettelijke verplichting — bewijsplicht art. 7)
Bewaartermijn	5 jaar na intrekking
Beveiligingsmaatregelen	Append-only; blijft bij sessie-verwijdering (ON DELETE SET NULL)
Doorgifte buiten EU	Nee

11. Leefstijlplan-voortgang

Doel	Stap-voortgang per domein bijhouden in het leefstijlplan
Betrokkenen	Intake-gebruikers met actieve sessie
Soort gegevens	Pseudoniem sessie-id, domein, stap-statussen (enums)
Bijzondere gegevens	Nee in plan_progress zelf
Ontvangers	Supabase
Grondslag	Art. 6 lid 1 sub a (toestemming supplementadvies / analytics-scope)

Bewaartermijn	Volgt intake-retentie; revoke-keten (tracking-en-privacy.md)
Beveiligingsmaatregelen	Geen vrije tekst in voortgang; RLS
Doorgifte buiten EU	Nee

12. Evidence-chat

Doel	Vragen beantwoorden uit gepubliceerde evidence-database (geen vrije generatie)
Betrokkenen	Websitebezoekers
Soort gegevens	Vraagtekst (server-side verwerkt, niet opgeslagen als profiel), event evidence.chat_queried (theme_slug, in_scope)
Bijzondere gegevens	Nee in opgeslagen events
Ontvangers	Supabase (evidence-tabellen)
Grondslag	Art. 6 lid 1 sub f (gerechtvaardigd belang — informatievoorziening)
Bewaartermijn	Events volgen domain_events-retentie; geen chatlog-persistentie
Beveiligingsmaatregelen	Alleen gepubliceerde claims; disclaimer; geen diagnose-taal
Doorgifte buiten EU	Nee

13. Premium-wachtlIJst & launch-mail

Doel	Intentie voor premium begeleiding vastleggen; optioneel e-mail bij productlaunch
Betrokkenen	Ingelogde dashboard-gebruikers die vrijwillig op de wachtlijst staan
Soort gegevens	Account-id, feature-key (premium-coaching), optionele prijsband, bron-surface; bij launch-opt-in: e-mailadres (via account), consent-record
Bijzondere gegevens	Nee in premium_waitlist; launch-mail koppelt aan account met gekoppelde intake
Ontvangers	Supabase (premium_waitlist, consent_records); bij launch: Resend (VS — DPF)
Grondslag	Art. 6 lid 1 sub a (toestemming launch-mail); wachtlijst zonder mail-opt-in: art. 6 lid 1 sub f (productvalidatie)
Bewaartermijn	Wachtlijst tot launch + 12 maanden daarna of tot intrekking; consent-records 5 jaar na intrekking
Beveiligingsmaatregelen	Alleen ingelogde accounts; expliciete checkbox voor launch-mail; consent-tekst + versie in consent_records
Doorgifte buiten EU	Ja — alleen bij launch-mail via Resend (VS, DPF)

14. Error monitoring (Sentry)

Doel	Technische stabiliteit: productiefouten detecteren en oplossen
Betrokkenen	Websitebezoekers en ingelogde gebruikers bij een server- of clientfout
Soort gegevens	Stack traces, fouttype, request-URL (geen query/body op gevoelige routes), apparaattype/browser; geen e-mail, geen intake-antwoorden
Bijzondere gegevens	Nee — scrubber dropt events van intake/contact/waitlist-routes en health-velden
Ontvangers	Sentry (SaaS; EU-regio bij projectconfiguratie)
Grondslag	Art. 6 lid 1 sub f (gerechtvaardigd belang — beveiliging en stabiliteit)
Bewaartermijn	90 dagen (Sentry default)
Beveiligingsmaatregelen	beforeSend-scrubber; sendDefaultPii: false; geen DSN = geen verzending; DPA vereist vóór prod-DSN
Doorgifte buiten EU	Alleen indien Sentry-project buiten EU staat — standaard EU-project aanbevolen
Actief	Prod-DSN geconfigureerd; scrubber + sendDefaultPii: false; alleen errors (geen Replay)

Verwerkersovereenkomsten (art. 28)

Mechanisme: bij SaaS-verwerkers volstaat **acceptatie van de verwerkersvoorwaarden in het product** (licentie/DPA-flow); geen aparte handtekening vereist. Bewijs = geaccepteerde voorwaarden + archiefbestand of screenshot met datum.

Verwerker	Status	Locatie data	Archief / bewijs
Supabase	Geaccepteerd (DPA 2026-06-01)	EU (Frankfurt)	Supabase+DPA+260601.pdf (+ Supabase+TIA+250314.pdf)
Hetzner	Geaccepteerd (DPA in productvoorwaarden)	EU (Duitsland)	DPA_en hetzner.pdf -compressed.pdf
Cloudflare	Geaccepteerd (Customer DPA v6.4, apr 2026)	Wereldwijd	cloudflare_customer_dpa-v6.4_april_3_2026.pdf
Resend	Geaccepteerd (DPA)	VS (DPF)	resent-dpa-signed.pdf
Google (Analytics 4)	Geaccepteerd 23-11-2022 in GA4 Accountinstellingen	VS (DPF + Google Ads Data Processing Terms)	dpa/Google_Analytics_DPA_geaccepteerd_2026-07-04.png
Microsoft (Clarity)	Geaccepteerd (Microsoft Product and Services DPA)	VS (DPF)	dpa/MicrosoftProductandServicesDPAClarity.docx

Verwerker	Status	Locatie data	Archief / bewijs
Zoho CRM	Te accepteren — checklist docs/legal/Zoho_CRM_DPA_accepteren.md	EU	Na acceptatie: dpa/Zoho_CRM_DPA_geaccepteerd_[datum].pdf
Sentry	Geaccepteerd (DPA 5.1.0, 16 jul 2026)	EU (projectregio)	dpa/Sentry_DPA_geaccepteerd_2026-07-16.png

Niet actief in productie (geen verwerkersovereenkomst nodig zolang uit):

Dienst	Status
PostHog	Voorbereid in code (deliveredTo: "posthog"), geen SDK/API actief
n8n	Voorbereid in code; vereist N8N_WEBHOOK_URL — niet geconfigureerd

Onderhoudsregels

1. **Maandelijks** (1e werkdag): read-only controle via docs/cursors/monthly-privacy-register-review.md. Als alles klopt: noteer in wijzigingslog "*Gecontroleerd, geen wijziging*" + datum.
2. **Bij wezenlijke wijziging** (nieuwe verwerker, nieuw datatype, nieuwe tabel/API): update dit register **in dezelfde PR** als de codewijziging.
3. **Datum**: elke inhoudelijke wijziging krijgt een nieuwe Laatste bijgewerkt-datum + regel in de wijzigingslog. Een kale controle zonder wijziging hoeft de hoofddatum niet te veranderen — alleen de logregel.
4. **DPIA**: apart document (DPIA.md + PDF in docs/legal/pdf/); herziening jaarlijks of bij wezenlijke risicowijziging. Verwerkingsregister en DPIA verwijzen naar elkaar maar dienen verschillende AVG-artikelen.
5. **PDF's opnieuw genereren**: npm run generate-legal-pdfs (privacy, register, DPIA, datalekprocedure).

Wijzigingslog

Datum	Wijziging
2026-07-16	Sentry DPA 5.1.0 geaccepteerd + prod-DSN actief (EU-regio; aggregated identifying data uit)
2026-07-16	Sentry error monitoring toegevoegd (code + scrubber)
2026-07-16	Cookie-consent pre-deploy checklist afgevink (prod)
2026-07-16	GA4 account hardening gecontroleerd (land NL, delen uit, retentie 14m)

Datum	Wijziging
2026-07-04	Eerste versie in repo — samengesteld uit privacyverklaring, DPIA PDF (apr 2026), codebase
2026-07-04	Privacyverklaring gesynchroniseerd; PostHog/n8n als niet-actief vastgelegd
2026-07-04	Verwerkersovereenkomsten ingevuld; archief in Documenten/.../privacy/ (Zoho nog open)
2026-07-04	GA DPA-screenshot gearchiveerd; losse datalekprocedure-one-pager toegevoegd
2026-07-04	Archiefstructuur privacy/ (dpa/, dpia/, verwerkingsregister/, incidenten/); GA-filename gecorrigeerd; Zoho DPA-checklist toegevoegd